

tp cybersécurité PIA 1

Matisse

kra

bts sio 1

Sommaire

Problème	2
mise en place de la solution :	2
sous problème 1 analyser un PIA	2
sous-problème 2 — Réaliser une cartographie des traitements	7
Sous Probleme 3 Repérer l'utilisation des données à caractère personnel	8
Sous Probleme 4 Traitements et risques sur les données à caractère personnel	8
Sous Problem 5 Dissocier les notions de sécurité et de sûreté informatique	9
Sous Probleme 6 Recensez les données qui correspondent à la définition d'une donnée à caractère personnel.	10
Conclusion	11

Problème

l'objectif est de savoir répondre à l'exigence de sécurité du système d'information d'une organisation en prenant en compte toutes ses dimensions (technique, organisationnelle, humaine, juridique)

mise en place de la solution :

Le document fourni en cours nous guide sur les différentes opérations à réaliser pour répondre aux exigences de sécurité du système d'information d'une organisation. la solution se décompose en plusieurs sous problèmes

sous problème 1 analyser un PIA

j'ai importé le travail réalisé par M. Grospre dans l'application PIA

The screenshot displays the 'PIA TESTOP' application interface. The main header shows 'Mes PIAs > PIAs Actifs > (IMPORT) PIA TESTOP'. The left sidebar contains navigation menus for 'CONTEXTE', 'PRINCIPES FONDAMENTAUX', 'RISQUES', and 'VALIDATION'. The 'RISQUES' menu is currently selected, showing a list of risk categories: 'Mesures existantes o...', 'Accès illégitime à des ...', 'Modification non dési...', 'Disparition de données', and 'Vue d'ensemble des ris...'. The main content area is titled 'Risques' and includes a description: 'Cette section vous permet d'apprécier les risques sur la vie privée, compte tenu des mesures existantes ou prévues.' Below this, there is a section for 'MESURES EXISTANTES OU PRÉVUES' with a description: 'Cette partie vous permet de recenser les mesures (existantes ou prévues) contribuant à la sécurité des données.' A green button labeled '+ Créer une mesure (ou en ajouter une proposée dans la base de connaissances à droite)' is visible. The 'Chiffrement' risk is highlighted, with a description: 'Un chiffrement des flux de données est réalisé par le protocole SSL.' and a date of '15/09/2019'. The right sidebar shows the 'Base de connaissances' section, which allows users to select a knowledge base (currently 'Base de connaissances CNIL') and search for measures. A list of filters is provided, including 'Tout', 'Définitions', 'Mesures organisationnelles', 'Mesures sur les données', and 'Mesures générales de sécurité du système'. The 'Mesures sur les données' filter is expanded, showing 'Chiffrement' and 'Anonymisation' with green plus icons and the label 'Ajouter'.

puis après l'avoir importé j'ai analysé les différents risques puis évalué leur niveau de vraisemblance

1-ACCÈS ILLÉGITIME À DES DONNÉES

Comment estimez-vous la **gravité du risque**, notamment en fonction des impacts potentiels et des mesures prévues ?



(Non définie)

Négligeable

Limitée

Importante

Maximal

gravité du risque

Comment estimez-vous la **vraisemblance du risque**, notamment au regard des menaces, des sources de risques et des mesures prévues ?



(Non définie)

Négligeable

Limitée

Importante

Maximale

niveau vraisemblance

2. MODIFICATION NON DÉSIRÉES DE DONNÉES

Comment estimez-vous la **gravité du risque**, notamment en fonction des impacts potentiels et des mesures prévues ?



Comment estimez-vous la **vraisemblance du risque**, notamment au regard des menaces, des sources de risques et des mesures prévues ?



3. DISPARITION DE DONNÉES

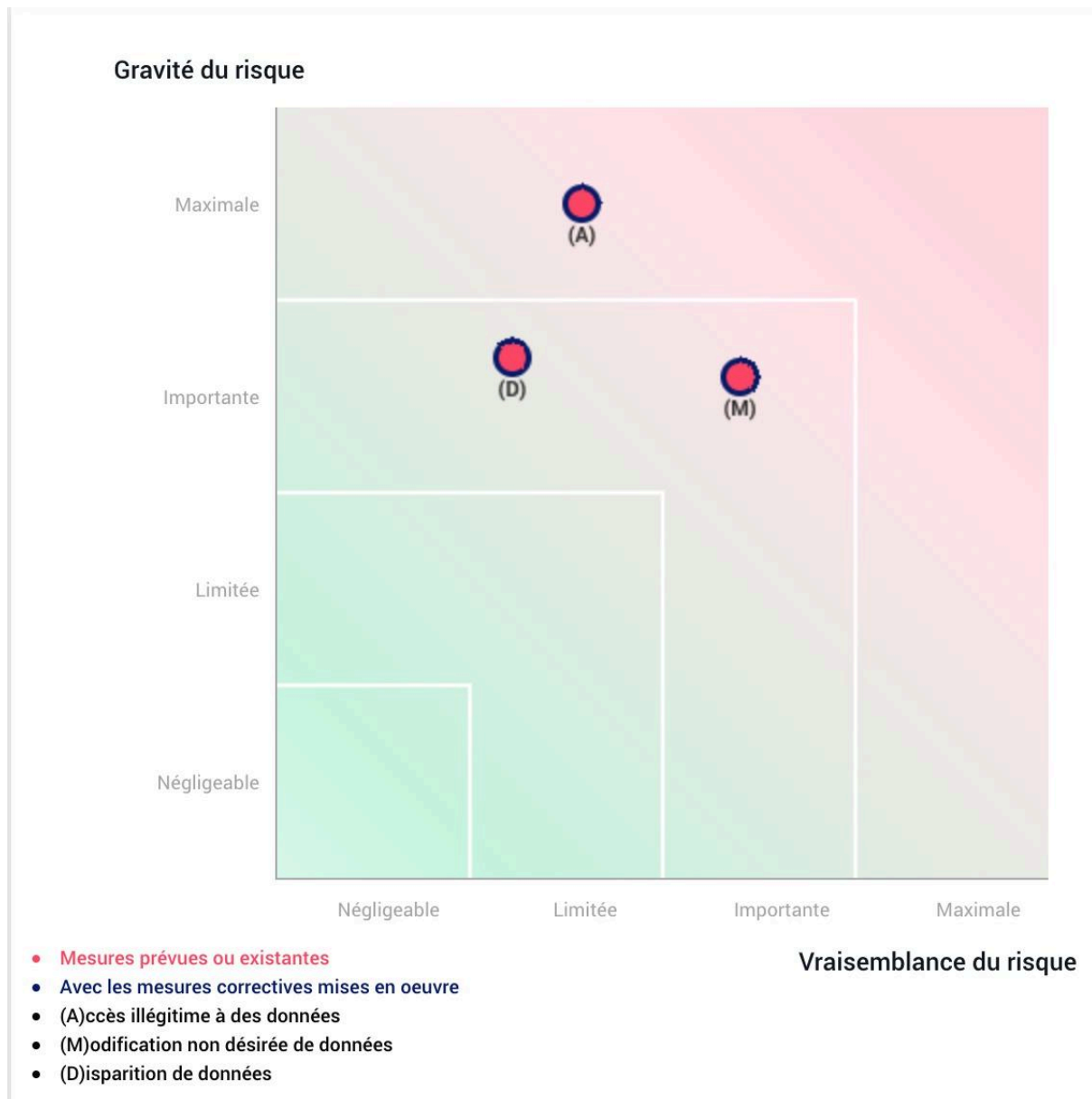
Comment estimez-vous la **gravité du risque**, notamment en fonction des impacts potentiels et des mesures prévues ?



Comment estimez-vous la **vraisemblance du risque**, notamment au regard des menaces, des sources de risques et des mesures prévues ?



cartographie des risque



La cartographie des risques vise à évaluer les impacts potentiels sur la vie privée liée à la mise en place d'un outil de suivi RH. elle couvre les traitements de données relatifs aux salariés. Les risques sont positionnés selon leur vraisemblance et leur gravité. les zones rouge indiquent des risques nécessitant un plan d'action prioritaire.

à partir de cette cartographie des risques j'ai effectué une demande d'évaluation pour les item liée au risque puis proposer des mesure correctrice envisageable pour renforcer la sécurité.

1. le chiffrement: ameliorable

Un chiffrement des flux de données est réalisé par le protocole SSL.

Analyse

Le protocole SSL (Secure Socket Layer) est aujourd'hui obsolète et remplacé par TLS (Transport Layer Security). SSL présente des vulnérabilités connues et ne garantit plus une sécurité suffisante pour la confidentialité des flux.

Plan d'action / mesures correctives

- Mettre à jour le chiffrement en adoptant le protocole TLS 1.2 ou 1.3.
 - Interdire l'usage de SSL sur les serveurs.
 - S'assurer de la gestion des certificats (renouvellement, signature par une autorité de confiance).
 - Vérifier que toutes les communications internes et externes sont chiffrées (ex. entre serveurs, bases de données, applications web).
2. Contrôle des accès logiques: a corrigé

Seules les personnes habilitées peuvent consulter les données personnelles des salariés. Le login correspond à leur nom de famille et le mot de passe à leur date de naissance.

Analyse

L'utilisation de la date de naissance comme mot de passe est une faille majeure de sécurité (facilement devinable, non conforme aux bonnes pratiques RGPD et ANSSI). De plus, le login nominatif ne suffit pas à garantir une sécurité correcte sans politique de mot de passe robuste.

Mesures correctrices envisageables :

- Imposer des mots de passe forts (longueur minimale, complexité, renouvellement périodique).
 - Mettre en place une authentification à deux facteurs (2FA) pour les accès sensibles.
 - Gérer les habilitations via une politique d'accès basée sur les rôles (principe du moindre privilège).
 - Créer une procédure de révocation immédiate des accès lors du départ d'un salarié.
3. Archivage: amélorable

Les données sont sauvegardées sur un disque dur externe puis celui-ci est amené au service informatique pour le transfert dans une base de données de TESTOP et vers un serveur hébergé par la société OVH.

Analyse

La méthode de sauvegarde physique (disque dur externe) peut poser problème en matière de sécurité physique et de traçabilité. Il n'est pas précisé si les données sont chiffrées ni combien de temps elles sont conservées.

Plan d'action / mesures correctives

- Chiffrer les sauvegardes avant tout transfert.
 - Mettre en place une politique d'archivage claire (durée de conservation, destruction sécurisée).
 - Documenter les transferts de données et assurer la traçabilité des accès.
 - Vérifier le niveau de conformité RGPD d'OVH (hébergement au sein de l'UE, clauses contractuelles).
 - Éviter le transfert manuel sur disque dur, privilégier un système de sauvegarde automatisé et sécurisé
4. Gestion des postes de travail: à corriger

L'ouverture de la session du poste de travail qui sert à la collecte des données à caractère personnel est assurée par un login et un mot de passe uniques pour tout le service de la gestion du personnel.

Analyse

Un identifiant partagé entre plusieurs utilisateurs empêche toute traçabilité individuelle et viole les principes de sécurité RGPD (impossibilité d'identifier qui accède ou modifie des données).

Mesures correctrices envisageables :

- Créer un compte utilisateur individuel pour chaque agent.
- Appliquer une politique de verrouillage automatique du poste après inactivité.
- Mettre en place une journalisation des connexions et actions sur les données sensibles.
- Former les utilisateurs aux bonnes pratiques de cybersécurité.

Après mise en œuvre des mesures correctrices, les risques majeurs passent d'un niveau maximal à important. La probabilité d'accès illégitime diminue grâce à une meilleure gestion des accès, et le risque de disparition est fortement réduit grâce à des sauvegardes automatisées.

sous-problème 2 — Réaliser une cartographie des traitements

La cartographie des traitements consiste à :

- Identifier tous les traitements de données personnelles effectués dans une organisation (collecte, utilisation, stockage, partage, suppression, etc.), en précisant :
 - les acteurs concernés (responsables, sous-traitants, destinataires),
 - les finalités (objectifs du traitement),
 - les données traitées (ex : nom, CV, mail...),
 - les durées de conservation,
 - et les mesures de sécurité mises en place.
- Enjeux :
 - Respecter le RGPD (transparence et traçabilité),
 - Identifier les risques de non-conformité,
 - Préparer les analyses d'impact (PIA),
 - Faciliter la gestion des droits des personnes (accès, rectification, effacement...).
- Pourquoi le registre des traitements est une étape préalable ?
- Le registre des traitements est un document listant tous les traitements de données effectués par l'entreprise.

C'est une base de référence obligatoire avant toute cartographie : il permet de recenser les processus, puis de les représenter visuellement dans la cartographie pour mieux comprendre les flux de données et les risques associés.

Sous Probleme 3 Repérer l'utilisation des données à caractère personnel

Précisez les conséquences de la saisie de données personnelles sur un formulaire d'inscription au site [castorama.fr](https://www.castorama.fr),

Quand tu t'inscris sur castorama.fr et que tu donnes tes infos, sache qu'elles peuvent circuler. Kingfisher, la maison mère (avec Brico Dépôt et Screwfix), et d'autres entreprises peuvent y avoir accès. Ton email, tes achats, tout ça sert à piger ce que tu aimes, à rendre les services meilleurs et à te balancer des promos sur mesure. En gros, tes infos servent à te vendre des trucs.

La confidentialité est-elle assurée ?

Difficile à dire juste avec ce texte. Il parle de partage d'infos, mais il ne dit rien des protections mises en place (cryptage, anonymisation, contrôle d'accès, etc.). Le fait que tes infos passent de main en main augmente quand même le risque qu'elles se fassent la malle ou qu'elles soient mal utilisées si la sécurité n'est pas béton.

Sous Probleme 4 Traitements et risques sur les données à caractère personnel

Comment on prend, garde et partage les données ?

Récupération :

On prend les données via des formulaires en ligne (genre sur castorama.fr), les outils RH internes pour les employés, ou on les note direct dans les bases de données, à la main ou automatiquement.

Stockage :

Elles sont gardées sur des serveurs internes ou chez un hébergeur (comme OVH), sur des disques durs externes pour les copies de sauvegarde, et parfois dans des logiciels ou des bases locales, par exemple TESTOP.

Partage :

Les infos peuvent circuler dans le groupe (Kingfisher, Brico Dépôt, etc.), certains services internes (RH, direction) peuvent y avoir accès, ou elles sont envoyées par mail ou synchronisées entre les serveurs.

Ce qu'on fait avec les données personnelles

On prend et on gère les données RH (identité, contrat, salaire...), on les archive et on fait des sauvegardes régulières. L'accès est contrôlé avec des identifiants et des mots de passe, et les transferts entre serveurs sont cryptés. Une analyse d'impact (PIA) sert à voir les risques de ces traitements. Les données clients peuvent aussi servir au marketing, pour faire du profilage ou de la pub ciblée.

Ce que la loi dit (RGPD / CNIL)

Il faut dire aux gens comment on prend et utilise leurs données, ne prendre que le strict minimum, assurer la sécurité et la confidentialité, et pas garder les infos plus longtemps que nécessaire. Chacun doit pouvoir voir ses données, les corriger ou demander à les supprimer. Il faut tenir un registre des traitements à jour, faire une analyse d'impact (PIA) pour les traitements sensibles, et prévenir la CNIL si les données fuient.

Ce qui arrive si on ne respecte pas les règles

La CNIL peut commencer par un avertissement, mais les sanctions peuvent vite monter : jusqu'à 10 millions d'euros ou 2 % du chiffre d'affaires mondial pour des problèmes techniques, et 20 millions d'euros ou 4 % pour des violations graves du RGPD. Il y a aussi des sanctions pénales : jusqu'à 5 ans de prison et 300 000 € d'amende. Et en plus des amendes, on risque de perdre la confiance des clients et des partenaires, ce qui n'est pas bon pour l'image.

Sous Problem 5 Dissocier les notions de sécurité et de sûreté informatique

Scénarios	Sécurité	Sûreté	Justifications
L'ensemble des serveurs est hors service à cause d'une inondation du local technique		✓	Cet incident est d'origine naturelle (catastrophe, événement physique). Il ne résulte pas d'une attaque humaine : c'est donc un problème de sûreté (protection contre les événements accidentels ou environnementaux).
Les données d'un hôpital sont illisibles à la suite d'une attaque de type ransomware	✓		Le ransomware est une attaque malveillante volontaire visant à chiffrer ou voler des données. C'est un risque de sécurité informatique (menace intentionnelle).
L'apparence du site vitrine d'une entreprise est modifiée par des personnes malveillantes	✓		La défiguration d'un site web est un acte délibéré (piratage). C'est une atteinte à la sécurité : intégrité et disponibilité des informations sont compromises.
Une surcharge électrique temporaire due à des travaux provoque une panne des routeurs		✓	Cet incident est accidentel et non intentionnel. Il relève de la sûreté, car il s'agit d'un problème physique ou technique sans action humaine malveillante.

Sous Probleme 6 Recensez les données qui correspondent à la définition d'une donnée à caractère personnel.

Données	Caractère personnel	Justifications
Le nom de l'enseigne du magasin Carrefour	Non	Il s'agit d'une personne morale (entreprise) et non d'une personne physique. Le RGPD ne s'applique qu'aux données concernant des individus identifiables.
L'adresse courriel professionnelle d'un directeur des services informatiques	Oui	Même si elle est professionnelle, elle identifie directement une personne physique (ex. prénom.nom@entreprise.fr).
Une photo postée sur un réseau social	Oui	Une photo permet d'identifier ou de reconnaître une personne physique. Elle entre donc dans la définition du RGPD.
Une vidéo de présentation de son parcours professionnel envoyée à une entreprise dans le cadre d'un recrutement	Oui	Elle contient des éléments personnels (image, voix, parcours, identité) permettant d'identifier la personne.
Les coordonnées GPS de localisation d'un smartphone	Oui	Elles permettent de suivre ou identifier indirectement une personne en fonction de ses déplacements.
Le groupe sanguin d'un patient stocké sur le serveur de son médecin	Oui	Il s'agit d'une donnée de santé, considérée comme sensible au sens du RGPD (article 9).
Les enregistrements de vidéosurveillance d'un datacenter	Oui	Les vidéos peuvent montrer des visages ou comportements permettant d'identifier des personnes physiques.
Le numéro d'enregistrement au registre du commerce et des sociétés (RCS) d'une entreprise	Non	Le RCS identifie une entreprise et non une personne physique. Ce n'est pas une donnée à caractère personnel.
Le numéro de sécurité sociale d'un salarié saisi sur sa fiche d'embauche	Oui	C'est un identifiant unique permettant d'identifier directement une personne physique : donnée personnelle très sensible.

Conclusion

En conclusion, ce TP m'a permis de comprendre concrètement comment identifier, analyser et réduire les risques liés aux traitements de données personnelles dans le cadre d'une démarche RGPD. Grâce à l'utilisation de l'outil PIA, j'ai pu évaluer les menaces, proposer des mesures correctrices (chiffrement, authentification forte, archivage sécurisé...) et mesurer leur impact sur la sécurité du système d'information. J'ai également appris à distinguer la sécurité (protection contre les attaques intentionnelles) de la sûreté (prévention des incidents accidentels), et à reconnaître les différentes catégories de données à caractère personnel. Ce travail renforce ma capacité à contribuer à la conformité et à la protection des données au sein d'une organisation.